

HOSPITAL CAMPINAS SAÚDE

Hospital Matriz • UPA Ouro Verde • UPA Campo Grande

ETAPA 4

MECANISMOS DE SEGURANÇA DA INFORMAÇÃO

Campo	Informação
Projeto	Hospital Campinas Saúde
Disciplina	Projeto de Infraestrutura de Redes
Etapa	4 — Mecanismos de Segurança da Informação
Integrantes	Ítalo Rangel Penaforte, João de Sousa Lourenco, Rodrigo Cattoi, Rodrigo Lima, Ryann Parreira
Professor	Alexandre Teixeira
Data	Junho de 2026
URL da Aplicação	http://3.229.138.132:3000/

1. Introdução

Esta etapa do projeto tem como foco os aspectos de Segurança da Informação da solução de infraestrutura desenvolvida para o Hospital Campinas Saúde e suas filiais — UPA Ouro Verde e UPA Campo Grande. Com a infraestrutura de rede já implantada e os servidores configurados nas etapas anteriores, o presente documento concentra-se em três frentes:

- Análise de vulnerabilidades do ambiente de servidor onde a aplicação está implantada, com base no OWASP Top 10 2025
- Deploy e disponibilização da aplicação back-end em ambiente de nuvem (Amazon ECS)
- Documentação da Política de Segurança da Informação e Cartilha de Boas Práticas, entregues em documentos separados

A análise de vulnerabilidades realizada neste documento não se limita ao código da aplicação, mas abrange o ambiente completo — configuração do servidor, exposição de portas, ausência de autenticação e transmissão de dados sensíveis — que compõem o cenário real de risco para uma instituição de saúde que lida com dados protegidos pela LGPD.

2. Infraestrutura Implantada

2.1 Visão Geral da Rede

A infraestrutura do Hospital Campinas Saúde foi projetada com três unidades interconectadas via links dedicados, simulados no Cisco Packet Tracer. A unidade Matriz concentra os servidores principais, enquanto as UPAs acessam os sistemas centrais remotamente.

Unidade	IP / Gateway	Range	Hosts
Hospital Matriz (Core)	192.168.0.1	192.168.0.1/24	61 hosts
UPA 1 — Ouro Verde	192.168.1.1	192.168.1.1/24	17 hosts
UPA 2 — Campo Grande	192.168.2.1	192.168.2.1/24	17 hosts

2.2 Servidor de Aplicação — Amazon ECS

Para a Etapa 4, a aplicação back-end foi implantada em um servidor na nuvem utilizando o serviço Amazon ECS (Elastic Container Service), atendendo ao requisito de disponibilização em nuvem.

Item	Detalhe
Plataforma de Deploy	Amazon ECS (Elastic Container Service)
IP Público do Servidor	3.229.138.132
Porta da Aplicação	3000
URL de Acesso	http://3.229.138.132:3000/
Framework	Ruby on Rails 8.1.3
Linguagem	Ruby 4.0.5
Banco de Dados	SQLite 3
Protocolo	HTTP (sem TLS/SSL)

3. Aplicação Back-End Implantada

3.1 Descrição do Sistema

A aplicação desenvolvida é o Campinas Saúde API, um sistema de gestão de pacientes e atendimentos para a rede hospitalar. O sistema permite registrar e gerenciar pacientes, atendimentos em cada unidade (Matriz e UPAs) e transferências entre unidades, representando o fluxo real de uma rede hospitalar.

3.2 Módulos do Sistema

Módulo	Funcionalidades	Dados Gerenciados
Unidades	CRUD completo das unidades da rede	Hospital Matriz, UPA Ouro Verde, UPA Campo Grande
Pacientes	Cadastro, consulta, edição e remoção	Nome, CPF, data de nascimento, telefone
Atendimentos	Registro de entrada, classificação de risco, status	Paciente, unidade, queixa, risco (Manchester), status
Transferências	Registro de movimentações entre unidades	Paciente, origem, destino, motivo, data/hora

3.3 Endpoints REST Disponíveis

Método	Rota	Descrição
GET	/unidades	Listar todas as unidades da rede
GET	/pacientes	Listar todos os pacientes
POST	/pacientes	Cadastrar novo paciente
PUT	/pacientes/:id	Atualizar dados de um paciente
DELETE	/pacientes/:id	Remover paciente
GET	/atendimentos	Listar todos os atendimentos
POST	/atendimentos	Registrar novo atendimento
PUT	/atendimentos/:id	Atualizar status do atendimento
GET	/transferencias	Listar transferências entre unidades
POST	/transferencias	Registrar nova transferência

4. Análise de Vulnerabilidades — OWASP Top 10 (2025)

O OWASP Top 10 é um documento de referência global que lista as dez vulnerabilidades mais críticas em aplicações web. A análise a seguir avalia o ambiente do Hospital Campinas Saúde — incluindo servidor, aplicação e infraestrutura de rede — frente a três vulnerabilidades selecionadas da edição 2025, identificando a suscetibilidade atual e as estratégias de mitigação aplicáveis ao contexto hospitalar.

4.1 A01:2025 — Quebra de Controle de Acesso

A01 Quebra de Controle de Acesso	
Nível de Risco CRÍTICO	Suscetibilidade SIM — Ambiente Suscetível
Contexto no Hospital Campinas Saúde A aplicação Campinas Saúde API está exposta publicamente na URL http://3.229.138.132:3000/ sem qualquer mecanismo de autenticação ou autorização implementado. Qualquer pessoa com acesso à internet pode listar, cadastrar, editar e excluir pacientes, atendimentos e transferências sem precisar se identificar. Não há distinção de perfis: um usuário anônimo possui os mesmos privilégios que um administrador do sistema. Além disso, a aplicação não implementa controle de acesso por unidade — um usuário da UPA Ouro Verde poderia acessar e manipular dados da UPA Campo Grande ou da Matriz sem restrição.	
Impacto Potencial Exposição total de dados de pacientes (nome, CPF, data de nascimento), que são dados pessoais sensíveis protegidos pela LGPD. Possibilidade de exclusão maliciosa de registros de atendimentos, comprometendo o histórico clínico dos pacientes. Manipulação fraudulenta de transferências entre unidades, podendo causar impacto direto no atendimento à saúde.	
Estratégias de Mitigação • Implementar autenticação obrigatória via JWT (JSON Web Token) ou sessions em todos os endpoints da API • Criar perfis de acesso baseados em função (RBAC): Administrador, Médico, Enfermeiro, Recepcionista • Restringir operações de escrita (POST, PUT, DELETE) a usuários autenticados com permissão específica • Implementar controle de acesso por unidade: cada usuário só acessa dados da sua unidade • Adicionar logs de auditoria para todas as operações de criação, edição e exclusão • Utilizar middleware de autenticação no Rails (Devise + Pundit) para centralizar o controle de acesso	

4.2 A02:2025 — Falhas Criptográficas

A02 Falhas Criptográficas	
Nível de Risco CRÍTICO	Suscetibilidade SIM — Ambiente Suscetível

Contexto no Hospital Campinas Saúde

A aplicação opera exclusivamente via protocolo HTTP, sem qualquer camada de criptografia TLS/SSL. Toda a comunicação entre o cliente (navegador ou Postman) e o servidor Amazon ECS é transmitida em texto puro, incluindo dados altamente sensíveis como CPF de pacientes, datas de nascimento, queixas clínicas e classificações de risco (protocolo de Manchester). No contexto da rede do hospital, a comunicação entre a Matriz e as UPAs também ocorre sem criptografia de ponta a ponta. O banco de dados SQLite armazena os dados sem criptografia em repouso.

Impacto Potencial

Interceptação de dados em trânsito por meio de ataques Man-in-the-Middle (MitM), expondo CPF e dados clínicos de pacientes — infração direta à LGPD. Qualquer agente na mesma rede pode capturar os pacotes e visualizar os dados com ferramentas simples como Wireshark. Em uma rede hospitalar com múltiplas VLANs e links dedicados entre Matriz e UPAs, o risco de interceptação interna é real. Multas e sanções da ANPD por vazamento de dados de saúde.

Estratégias de Mitigação

- Obter e configurar certificado TLS/SSL para o servidor ECS, habilitando HTTPS na porta 443
- Redirecionar automaticamente todo tráfego HTTP para HTTPS (force_ssl no Rails)
- Configurar HSTS (HTTP Strict Transport Security) para garantir que conexões futuras usem sempre HTTPS
- Criptografar campos sensíveis no banco de dados (CPF, dados clínicos) usando gem attr_encrypted no Rails
- Configurar VPN criptografada entre o servidor ECS e as unidades da rede (Matriz e UPAs)
- Garantir que backups do banco de dados SQLite também sejam armazenados de forma criptografada

4.3 A05:2025 — Configuração Incorreta de Segurança**A05 Configuração Incorreta de Segurança**

Nível de Risco
ALTO

Suscetibilidade
SIM — Ambiente Suscetível

Contexto no Hospital Campinas Saúde

O servidor Amazon ECS está configurado com a porta 3000 exposta publicamente sem restrições de IP ou firewall aplicados. A aplicação Rails está sendo executada em modo de desenvolvimento ou sem as configurações de produção adequadas (sem config.force_ssl, sem cabeçalhos de segurança HTTP, sem Content Security Policy). Não há configuração de rate limiting para prevenir ataques de força bruta ou enumeração de dados. A URL pública expõe diretamente o IP do servidor (3.229.138.132), sem proxy reverso (Nginx/Caddy) à frente, tornando visível a infraestrutura interna. Mensagens de erro detalhadas podem expor stack traces da aplicação Rails para usuários não autorizados.

Impacto Potencial

Exposição desnecessária da infraestrutura interna, facilitando ataques direcionados ao servidor. Ataques de força bruta e enumeração de dados de pacientes via API sem limitação de requisições. Vazamento de informações técnicas por mensagens de erro que revelam a tecnologia, versão e estrutura interna da aplicação. Exploração de configurações padrão do Rails que não foram endurecidas para ambiente de produção.

Estratégias de Mitigação

- Configurar o Security Group do Amazon ECS para restringir acesso apenas às portas necessárias (80 e 443)
- Posicionar um proxy reverso (Nginx ou AWS ALB) à frente da aplicação Rails, ocultando a porta 3000 e o IP direto
- Executar a aplicação em modo de produção (RAILS_ENV=production) com `config.consider_all_requests_local = false`
- Adicionar cabeçalhos de segurança HTTP: X-Frame-Options, X-Content-Type-Options, Content-Security-Policy
- Implementar rate limiting na API com gem rack-attack para prevenir enumeração e força bruta
- Configurar tratamento de erros personalizado para não expor stack traces em produção
- Desabilitar a página de boas-vindas padrão do Rails e qualquer rota de debug em produção

5. Resumo da Análise de Vulnerabilidades

Código	Vulnerabilidade	Risco	Suscetível?	Prioridade de Correção
A01:20 25	Quebra de Controle de Acesso	CRÍTICO	SIM	Imediata
A02:20 25	Falhas Criptográficas	CRÍTICO	SIM	Imediata
A05:20 25	Configuração Incorreta de Segurança	ALTO	SIM	Alta

As três vulnerabilidades identificadas são suscetíveis no ambiente atual e representam riscos reais para uma instituição de saúde que opera com dados pessoais sensíveis de pacientes. A ausência de autenticação e criptografia são as falhas mais críticas e devem ser tratadas com prioridade imediata, especialmente considerando as obrigações legais impostas pela LGPD ao Hospital Campinas Saúde como controlador de dados de saúde.

6. Conclusão

A Etapa 4 do Projeto de Infraestrutura de Redes do Hospital Campinas Saúde consolidou os aspectos de Segurança da Informação da solução desenvolvida ao longo do semestre. A aplicação back-end foi desenvolvida em Ruby on Rails 8.1.3 com Ruby 4.0.5, implementando um sistema de gestão de pacientes, atendimentos e transferências que representa o fluxo operacional real da rede hospitalar — Matriz, UPA Ouro Verde e UPA Campo Grande — e foi implantada com sucesso em servidor na nuvem Amazon ECS, acessível publicamente.

A análise de vulnerabilidades realizada com base no OWASP Top 10 2025 revelou que o ambiente atual apresenta falhas críticas de segurança, especialmente no controle de acesso, na ausência de criptografia em trânsito e em configurações incorretas do servidor. Essas vulnerabilidades são esperadas em um ambiente de desenvolvimento e aprendizado, e sua identificação — com as respectivas estratégias de mitigação documentadas — constitui o principal objetivo desta etapa.

Os documentos complementares desta etapa — Política de Segurança da Informação (PSI) e Cartilha de Boas Práticas de Acesso Seguro — foram elaborados de forma a cobrir os aspectos organizacionais e humanos da segurança da informação, garantindo que a solução técnica seja acompanhada de diretrizes claras para todos os colaboradores da rede hospitalar.